

What Is Offensive Security?

Unit 01 — Ethics, Law & the Hacker Mindset

Before we touch a single tool, we build judgment. This whole unit is one question: what's the difference between a hacker and a criminal?

Learning objectives

By the end of this unit you can:

- **Define** offensive security and explain *why* companies pay people to attack them.
- **Distinguish** white-, gray-, and black-hat hackers, and red team vs. blue team.
- **Describe** the "hacker mindset" — curiosity used ethically vs. harmfully.
- **Explain** in plain words what the CFAA prohibits, and that **minors are not exempt**.
- **Identify** authorization + scope as the one line between a pentester and a criminal.
- **Explain** responsible disclosure and how bug-bounty programs work.
- **Classify** real scenarios as legal/illegal and ethical/unethical — and justify it.
- **Set up** a lab journal you'll keep all semester.

What is offensive security?

- Testing systems by **attacking them — with permission** — to find weaknesses first.
- Also called **ethical hacking** or **penetration testing**.
- Core idea: **You can't protect what you don't understand.**

A penetration test is an *authorized, simulated attack* on a system to find and report weaknesses.

Hats: who's who

Hat	Who they are
 White hat	Works with permission, reports problems so they get fixed
 Black hat	Criminal — no permission, acts for harm, theft, or gain
 Gray hat	No permission but "good intentions" — still illegal & risky

Red team = the attackers (simulate real adversaries)

Blue team = the defenders (detect, respond, stop)

The hacker mindset

- Deep **curiosity** about how things really work.
- A drive to find clever, **unexpected uses** for a system.
- **Persistence** — the willingness to keep poking at a hard problem.

The same curiosity is a **defensive superpower** when it's authorized — and a crime when it isn't. The skill is identical; the *choice* is everything.

The law: CFAA

- **CFAA** = Computer Fraud and Abuse Act (18 U.S.C. § 1030) — the main U.S. anti-hacking law.
- It bans access "**without authorization**" and "**exceeding authorized access.**"
- State computer-crime laws add even more.
- **Minors are not exempt** — real charges, school discipline, lasting consequences.
- Even **scanning** or "just looking" can be illegal. Tools are *dual-use*: legal to own, illegal to use without permission.

Ethics & Authorization

Authorization is the **ONLY** line between a penetration tester and a criminal.

Everything offensive in this course happens **only** in isolated, pre-approved labs. Unauthorized access — even scanning or "just looking" — is illegal under the CFAA and state law. **Minors are not exempt.**

Authorization + scope

- **Authorization:** explicit, *written* permission from the owner to test a system.
- **Scope:** the exact list of systems, addresses, and actions you're allowed to test — **and nothing outside it.**

Going outside scope turns a legal pentest into a crime — instantly. Frustration is never an excuse to step outside the lines.

If you find a real vulnerability...

Do NOT exploit it, share it, or post it.

DO report it privately to the owner (or your teacher). That's **responsible disclosure** — and companies even pay for it through **bug-bounty** programs.

Report, don't exploit. That one habit defines a professional.

Scenario check: where's the line?

Scenario	Legal?	Why
Hired, signed contract, tests only listed servers		Authorized, in scope
Changes a number in the grade portal URL "just to confirm"		Exceeding authorized access
Finds the bug, changes nothing, emails IT privately		Responsible disclosure
Port-scans a website "to practice," no permission		"Just looking" is not a defense

Key vocabulary

Term	Meaning
Offensive security	Attacking systems <i>with permission</i> to find weaknesses first
Authorization	Explicit written permission to test a specific system
Scope	The exact systems/actions you're allowed to test — and no more
CFAA	Main U.S. federal anti-hacking law (18 U.S.C. § 1030)
Vulnerability / Exploit	A weakness / a technique that abuses that weakness
Responsible disclosure	Privately reporting a bug instead of exploiting it
Bug bounty	A program that pays ethical hackers to find bugs legally
AUP	Acceptable Use Policy — the rules you agree to follow

Lab launch

This week's lab has NO tools and NO hacking — that's the point. You build judgment before skills.

- **Platform:** none — discussion, classification, and role-play only.
- **Part 1:** Set up your **lab journal** (kept all semester) + a baseline entry.
- **Part 2:** Complete the **Scenario Worksheet** (8 cases: legal/illegal + ethical/unethical).
- **Part 3:** Responsible-disclosure **role-play** in pairs.

→ Full instructions in this unit's `lab.md`.

Recap

- Offensive security = attacking **with permission** to defend better.
- White / gray / black hats — gray is **still illegal**.
- The **CFAA** bans unauthorized access; **minors are not exempt**.
- **Authorization + scope** is the one dividing line.
- Found a bug? **Report, don't exploit**.
- Your **lab journal** starts now.

Exit ticket & discussion

Exit ticket: In your own words — what is the difference between a penetration tester and a criminal?

Discuss: A student finds the grading portal shows other students' grades by changing a number in the URL. What's the *right* move — and what could go wrong if they "just look around to be sure"?